

|                                                                                   |                                                                                                                                                                          |            |
|-----------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------|
|  | <b>UNIVERSIDAD DE ORIENTE - FACULTAD DE INGENIERIA Y ARQUITECTURA</b><br><b>Ciberseguridad Grupo "A" Tarea 1 Computo 1</b><br><b>Ing. Rolando Josías Colato Aparicio</b> |            |
|                                                                                   | Nombre:                                                                                                                                                                  | Fecha:     |
|                                                                                   | Código:                                                                                                                                                                  | 01/03/2026 |

### LABORATORIO 1:

Realice esta tarea de forma individual, debe presentarla en formato .PDF, agregue una caratula. El reporte no debe exceder de 10 paginas ni ser menor de 5.

Se evaluará presentación, lógica de análisis y originalidad, cualquier tarea repetida será dividida entre la cantidad de trabajos reproducidos. Fecha limite de entrega 1/03/2026

Al final de la tarea se adjunta un breve ejemplo de lo que se solicita.

-----  
Escenario: En la universidad se almacenan los siguientes datos en sus diferentes sistemas:

- Datos personales de estudiantes
- Expedientes académicos
- Información financiera

Y se sabe que el responsable es el Oficial de Seguridad de la Información.

Acorde a lo anterior el estudiante debe llevar a cabo los siguientes pasos:

- Paso 1: Identificación de Activos (bases de datos, aplicaciones de desarrollo y producción, infraestructura en la nube)
- Paso 2: Identificación de Amenazas (al menos 3 por cada activo)
- Paso 3: Identificación de Vulnerabilidades (al menos 3 por cada activo)
- Paso 4: Análisis del Riesgo (análisis por activo y general)
- Paso 5: Evaluación del Riesgo (crear matriz de riesgo con mapa de calor verde es bajo, amarillo es medio y rojo es critico)
- Paso 6: Tratamiento del Riesgo (matriz de plan de accion por cada riesgo)
- Paso 7: Documentación (documento formal)
- Paso 8: Monitoreo y Revisión (explicar que programas sugieren utilizar para dar monitoreo y que plan de revisión y seguimiento se va aplicar)

Resultado Final: El riesgo pasa de Crítico a Medio o Bajo, reduciendo la probabilidad de pérdida, alteración o filtración de información.

EJEMPLO CORTO:

## **INFORME DE GESTIÓN DE RIESGOS DE SEGURIDAD DE LA INFORMACIÓN**

**Organización:** Concesionaria de Vehículos UNIVO

**Responsable:** Oficial de Seguridad de la Información (CISO)

**Fecha:** de febrero de 2026

### **1. INTRODUCCIÓN**

El presente documento detalla el análisis y plan de tratamiento de riesgos para los activos críticos de la concesionaria, con el objetivo de proteger la integridad, disponibilidad y confidencialidad de los datos de empleados, clientes y financieros.

### **2. IDENTIFICACIÓN DE ACTIVOS (Paso 1)**

Se han priorizado tres categorías de activos esenciales:

- **Bases de Datos (BD):** Repositorios SQL con información financiera y datos personales (Ley de Protección de Datos).
- **Aplicaciones:** Sistemas de ventas (Producción) y entornos de prueba (Desarrollo).
- **Infraestructura en la Nube:** Servidores y almacenamiento en AWS/Azure para operaciones y backups.

### 3. MATRIZ DE AMENAZAS Y VULNERABILIDADES (Pasos 2 y 3)

| Activo                | Amenazas                                                                         | Vulnerabilidades                                                                                |
|-----------------------|----------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| <b>Bases de Datos</b> | 1. Ransomware.<br><br>2. Inyección SQL.<br><br>3. Robo de identidad.             | 1. Cifrado inexistente.<br><br>2. Parches desactualizados.<br><br>3. Contraseñas simples.       |
| <b>Aplicaciones</b>   | 1. Ataques DDoS.<br><br>2. Fuga de datos.<br><br>3. Acceso no autorizado.        | 1. Falta de MFA.<br><br>2. Errores de lógica en código.<br><br>3. Sesiones persistentes.        |
| <b>Nube</b>           | 1. Interrupción de servicio.<br><br>2. Configuración errónea.<br><br>3. Malware. | 1. Puertos abiertos innecesarios.<br><br>2. Permisos root compartidos.<br><br>3. Falta de logs. |

#### 4. ANÁLISIS Y EVALUACIÓN DEL RIESGO (Pasos 4 y 5)

El análisis inicial arroja un nivel de **Riesgo Crítico**.

##### Mapa de Calor (Estado Inicial)

| Impacto \ Prob. | Baja  | Media   | Alta             |
|-----------------|-------|---------|------------------|
| Crítico         | Medio | Crítico | Crítico (Actual) |
| Moderado        | Bajo  | Medio   | Crítico          |
| Bajo            | Bajo  | Bajo    | Medio            |

#### 5. PLAN DE TRATAMIENTO DEL RIESGO (Paso 6)

| Riesgo             | Acción                                     | Responsable          | Prioridad |
|--------------------|--------------------------------------------|----------------------|-----------|
| Pérdida de Datos   | Implementar Backups Inmutables.            | Oficial de Seguridad | Alta      |
| Acceso Ilegal      | Desplegar Autenticación Multifactor (MFA). | TI / Soporte         | Alta      |
| Vulnerabilidad App | Auditoría de código (Pentesting).          | Equipo Dev           | Media     |

#### 6. MONITOREO Y REVISIÓN (Paso 8)

Para mantener el riesgo en niveles **Bajos/Medios**, se implementará:

1. **Herramientas:** \* *Wazuh* (SIEM) para detección de intrusos.
  - *Nessus* para escaneo de vulnerabilidades mensual.
2. **Plan de Seguimiento:** \* Revisión trimestral de la matriz de riesgos.
  - Simulacros de recuperación ante desastres (DRP) cada 6 meses.

**RESULTADO ESPERADO:** Tras la aplicación de los controles, el riesgo residual se sitúa en la categoría **MEDIO-BAJO**, cumpliendo con los estándares de cumplimiento legal y protección corporativa.